
LABORATOIRE #5 PARTIE2

Cours 420-ZJ4-MO – Sécurité et éthique

NOM : ROMEO KOUÉMENI TONGAMBOU

CASSAGE DE MOT DE PASSE

Pour le laboratoire #5

VOTRE DOCUMENT OFFICE DOIT INCLURE:

- Ajoutez votre nom dans le document
- Une **numérotation** pour chaque partie du laboratoire. Vous devez bien séparer chaque partie.
- Un français acceptable. Assurez-vous de corriger les fautes de français et d'orthographe.
- Le laboratoire doit être fait **individuellement**.
- Mettez des captures d'écran et répondez aux questions lorsque demandé.

NO1 : AUDIT DES MOTS DE PASSE DU SYSTÈME À L'AIDE DE JEAN THE RIPPER

John the Ripper est un outil open source d'audit de sécurité des mots de passe et de récupération de mots de passe disponible pour de nombreux systèmes d'exploitation. Il prend en charge des centaines de types de hachage et de chiffrement, notamment ceux pour : les mots de passe utilisateur d'Unix, macOS, Windows, les "applications Web", les logiciels de groupe et les serveurs de bases de données.

Dans cet atelier, vous auditez les mots de passe du système à l'aide de l'utilitaire John the Ripper.

1. Connectez-vous sur la machine **Parrot Security** .
2. Cliquez sur l' icône **du terminal MATE** en haut de la fenêtre **du bureau** pour ouvrir une fenêtre **de terminal** .
1. tapez **sudo su** et appuyez sur **Entrée** pour exécuter les programmes en tant qu'utilisateur root.
2. Maintenant, tapez **cd** et appuyez sur **Entrée** pour accéder au répertoire racine.
3. Dans la fenêtre du terminal, tapez **adduser -gecos "jason"** et appuyez sur **Entrée** pour créer le premier utilisateur.
4. Lorsque vous y êtes invité, entrez le **nouveau mot de passe** de cet utilisateur : **alpha**

```
[attacker@parrot]-[~]
└─$ sudo su
[sudo] password for attacker:
[attacker@parrot]-[/home/attacker]
└─# adduser --gecos "" jason
Adding user `jason' ...
Adding new group `jason' (1001) ...
Adding new user `jason' (1001) with group `jason' ...
Creating home directory `/home/jason' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
[attacker@parrot]-[/home/attacker]
└─#
```

5. Créez les comptes supplémentaires suivants :
6. | Nom d'utilisateur | Mot de passe |
| martine | apple |

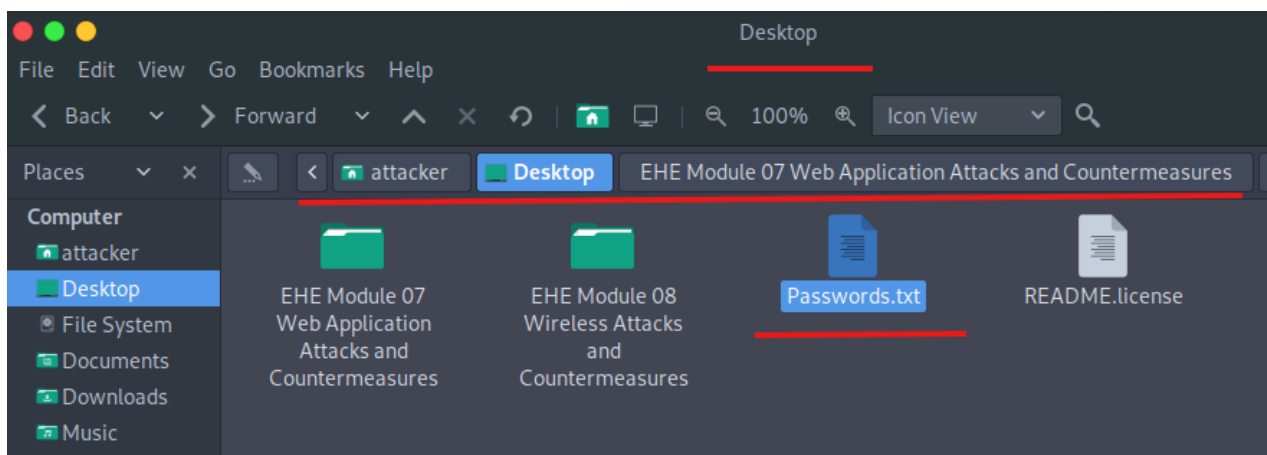
shiela	Z1BGZw
sam	green
larry	lki98LTyu!jyt

```
[root@parrot]-[/home/attacker]
#adduser --gecos "" martine
Adding user `martine' ...
Adding new group `martine' (1002) ...
Adding new user `martine' (1002) with group `martine' .
Creating home directory `/home/martine' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
[root@parrot]-[/home/attacker]
#adduser --gecos "" shiela
Adding user `shiela' ...
Adding new group `shiela' (1003) ...
Adding new user `shiela' (1003) with group `shiela' ...
Creating home directory `/home/shiela' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully
```

```
#adduser --gecos "" sam
Adding user `sam' ...
Adding new group `sam' (1004) ...
Adding new user `sam' (1004) with group `sam' ...
Creating home directory `/home/sam' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
passwd: password updated successfully

[root@parrot]-[/home/attacker]
#adduser --gecos "" larry
Adding user `larry' ...
Adding new group `larry' (1005) ...
Adding new user `larry' (1005) with group `larry' ...
Creating home directory `/home/larry' ...
Copying files from `/etc/skel' ...
New password:
Retype new password:
Sorry, passwords do not match.
passwd: Authentication token manipulation error
passwd: password unchanged
Try again? [y/N] y
New password:
Retype new password:
passwd: password updated successfully
```

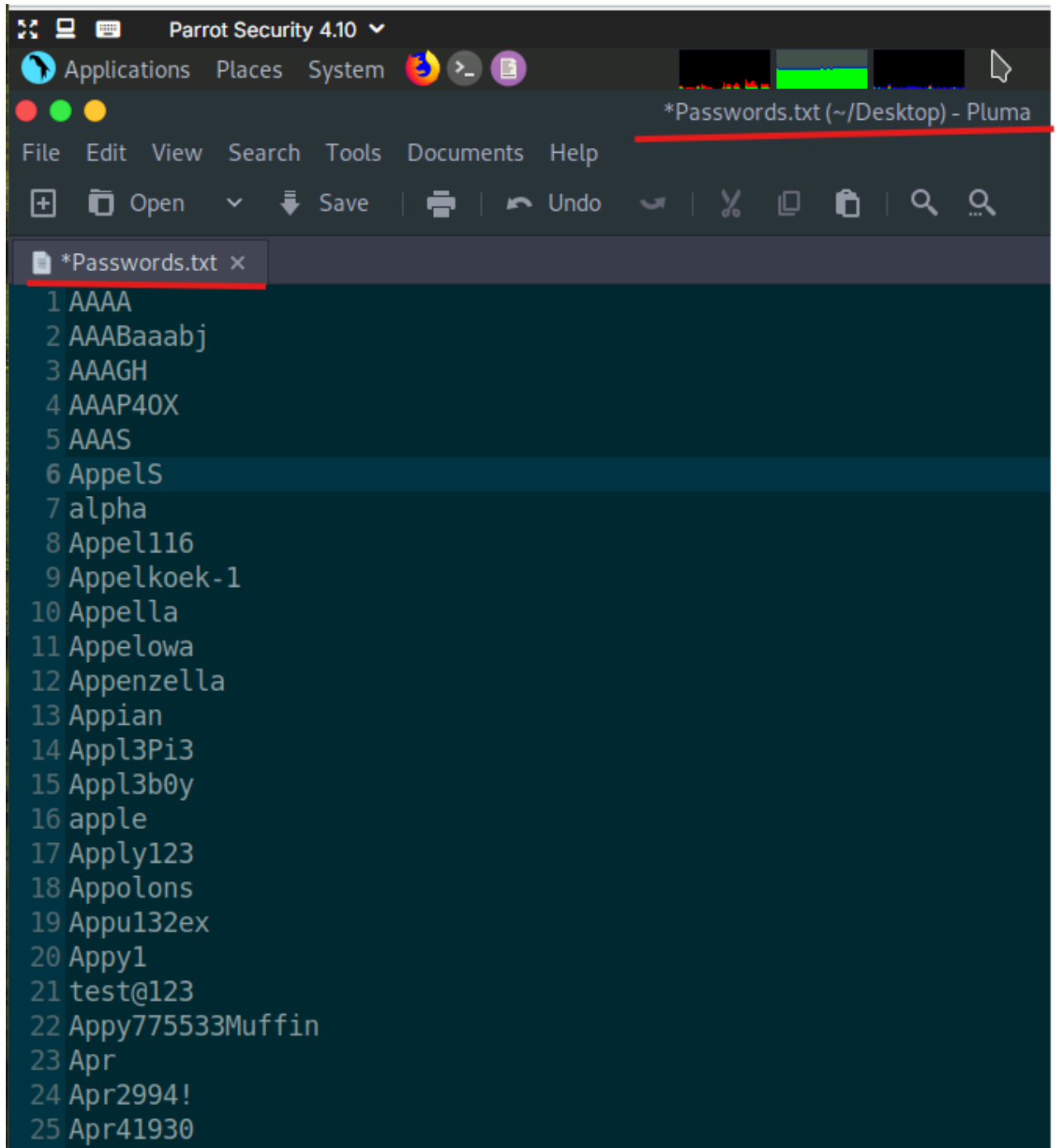
7. Maintenant, copiez le fichier **Passwords.txt** présent à l'emplacement **/home/attacker/Desktop/EHE Module 07 Web Application Attacks and Countermeasures/Wordlists** et collez-le à l'emplacement **/home/attacker/Desktop**.



8. Ouvrez le fichier copié et consultez son contenu.

9. **Que contient le fichier? Faites un imprime écran d'un extrait de ce fichier.**

Le fichier Passwords.txt contient une liste de mots de passe courants qui sert de dictionnaire pour les attaques par dictionnaire.



10. Maintenant, nous allons combiner les fichiers /etc/passwd et /etc/shadow, et utiliser ensuite John the ripper pour auditer les mots de passe des utilisateurs.

Que contient le fichier /etc/passwd? : Contient les informations de base des utilisateurs (nom, UID, GID, répertoire home, shell)

Que contient le fichier `/etc/shadow`? Contient les mots de passe hachés et les informations de sécurité

Dans le terminal, tapez `unshadow /etc/passwd /etc/shadow > target-file` et appuyez sur **Entrée** pour créer un fichier texte comprenant les noms d'utilisateur et les hachages de mots de passe.

11. **Faites un imprime écran d'un extrait du fichier `target-file` affichant les lignes contenant les utilisateurs créés plutôt. Que représente des 2 premières colonnes de chaque ligne.**

```
[root@parrot]-[/home/attacker]
#unshadow /etc/passwd /etc/shadow > target-file
Created directory: /root/.john

target-file [Read-Only] (~) - Pluma
File Edit View Search Tools Documents Help
+ Open Save Undo Cut Copy Paste Find
target-file x
52 colord*:133:145:colord colour management daemon,,,:/var/lib/colord:/usr/sbin/nologin
53 i2psvc*:134:146::/var/lib/i2p:/usr/sbin/nologin
54 dradis*:135:147::/var/lib/dradis:/usr/sbin/nologin
55 beef-xss*:136:148::/var/lib/beef-xss:/usr/sbin/nologin
56 geoclue*:137:149::/var/lib/geoclue:/usr/sbin/nologin
57 lightdm*:138:150:Light Display Manager:/var/lib/lightdm:/bin/false
58 king-phisher*:139:151::/var/lib/king-phisher:/usr/sbin/nologin
59 attacker:$6$UzzPFEQ3LeRMh4p$xe/NyhnWntbP6kfc30mjtgpSTRuZ/fUfFBEB3uH/-
Vc.sMP40gUedJ5937nKRhd6sR4P99PjT7HGbUX20DgX/:1000:1000:attacker,,,:/home/attacker:/bin/bash
60 systemd-coredump:!:999:999:systemd Core Dumper:/usr/sbin/nologin
61 gvm*:140:153::/var/lib/opensv:/usr/sbin/nologin
62 jason:-
$6$e7Nh0aGuQjws6nT5$Hx7xen6jsncqxHYbC0y.y2oFogTt6Pg0CTXLYfkpAHO6iW5rJLiI24zamNJzhLYQLiYls1Vb.-
6LXpdl/qtuP.:1001:1001::,/home/jason:/bin/bash
63 martine:$6$eWLVXlwn.JcUsBN$0MoGcdQUxvLHKRD1yz3NgU0N0JpXdK0FtwVorpi0l0sG7EeYkL0Wtvs1RUyilv.-
9lvhHiXwslvnH/4.vVM91.0:1002:1002::,/home/martine:/bin/bash
64 shiela:$6$ZEiGYhhWgMr8p7So$Y5WOKg7xMNx0EabZ.AYzZ/-
vdYFhpS8vTGNC02U99I4jfyCMSCQlosZYrBZQZz.HwwRbVjCsS2V4aI8Kyv22Vq1:1003:1003::,/home/shiela:/bin/-
bash
65 sam:-
$6$uDfXQXFcPhy2csI$frKsIstbEzbbSFGCXRbFnoeCEXjx02XPAgkQJj7n4xUwdT1poBQFRUFyFV875zxf1k8IziuYXJpFF5:
home/sam:/bin/bash
66 larry:-
$6$DfXnhaiUwBaCMbde$JWgcgXTb4aGn9v4epUSP9MFhXYSHSEjx5el1f0avFV5BpBxSzmRT.E4ev9qsoyhg.uIWQC09oPoIFwI
1005:1005::,/home/larry:/bin/bash
```

Les 2 premières colonnes représentent le nom d'utilisateur et le hash du mot de passe

12. Maintenant, tapez `john --wordlist=/home/attacker/Desktop/Passwords.txt target-file --format=crypt` et appuyez sur **Entrée** pour casser les mots de passe.
13. La liste des noms d'utilisateur et des mots de passe craqués s'affiche.

Faites un imprime écran des noms d'utilisateurs et des mots de passe cassés

```

#john --wordlist=/home/attacker/Desktop/Passwords.txt target-file --format=crypt
Using default input encoding: UTF-8
Loaded 7 password hashes with 7 different salts (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descript 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt])
is 6 for all loaded hashes
Cost 2 (algorithm specific iterations) is 5000 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
alpha      (jason)
apple      (martine)
green      (sam)
Warning: Only 77 candidates left, minimum 96 needed for performance.
Z1BGZw     (shiela)
4g 0:00:00:02 DONE (2025-11-03 09:19) 1.346g/s 58.24p/s 329.9c/s 329.9C/s Qx7fT..ZZ
Use the "--show" option to display all of the cracked passwords reliably
Session completed

```

14. Dans le terminal, tapez **john --show target-file > results.txt** et appuyez sur **Entrée** pour enregistrer le contenu du fichier cible dans un nouveau fichier (**results.txt**).

15. Faites un imprime écran du contenu du fichier **results.txt**.

```

[root@parrot]-[/home/attacker]
#john --show target-file > results.txt

```

```

1 jason:alpha:1001:1001:,,,:/home/jason:/bin/bash
2 martine:apple:1002:1002:,,,:/home/martine:/bin/bash
3 shiela:Z1BGZw:1003:1003:,,,:/home/shiela:/bin/bash
4 sam:green:1004:1004:,,,:/home/sam:/bin/bash
5

```

NO2 : AUDIT DES MOTS DE PASSE DU SYSTÈME À L'AIDE DE LOPHTCRACK

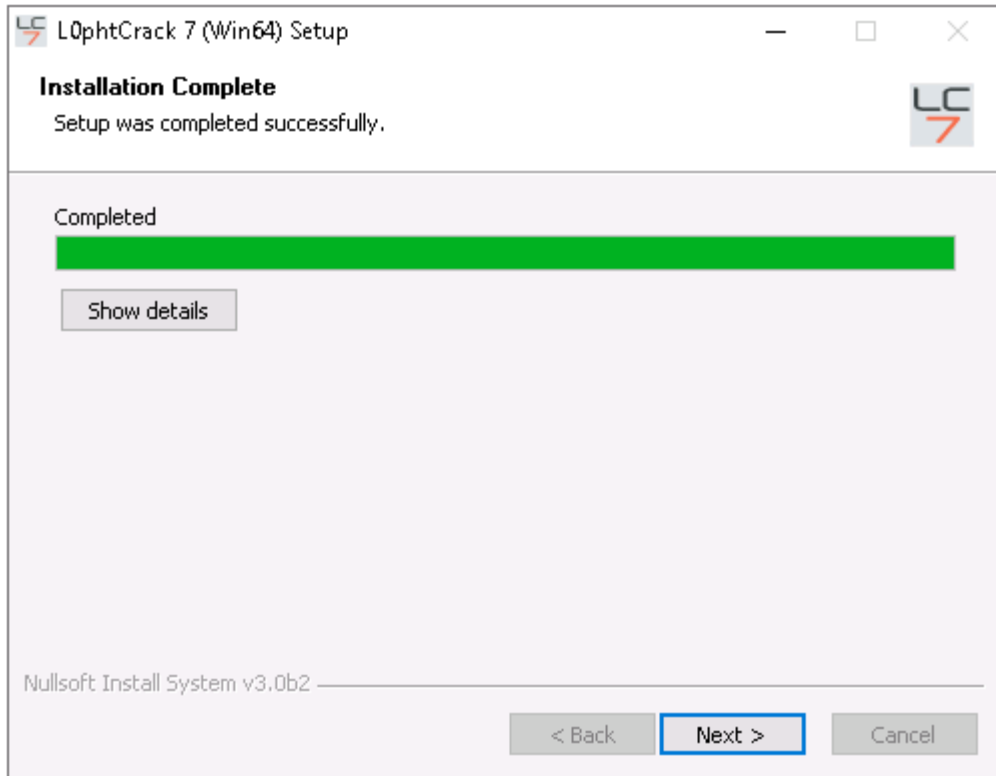
L0phtCrack est un outil conçu pour auditer les mots de passe et récupérer des applications. Il récupère les mots de passe Microsoft Windows perdus à l'aide d'attaques par dictionnaire, hybrides, arc-en-ciel (rainbow) et par force brute. Il peut également être utilisé pour vérifier la force d'un mot de passe.

Dans cet atelier, vous exécuterez l'outil L0phtCrack en fournissant à l'administrateur de la machine distante les informations d'identification de l'utilisateur.

Ici, nous auditerons les mots de passe du système à l'aide de L0phtCrack.

1. Connectez-vous sur la machine **Windows10**

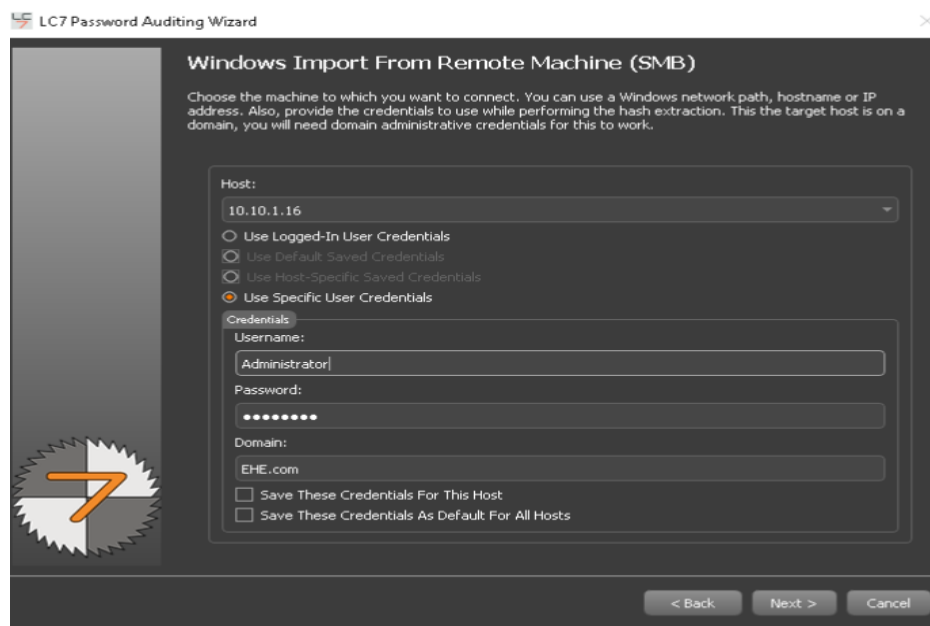
2. Accédez à **D:\EHE-Tools\EHEModule 04 Password Cracking Techniques and Countermeasures\Password cracking tools\L0phtCrack**; double-cliquez sur **lc7setup_v7.1.5_Win64.exe** pour installer **L0phtCrack**



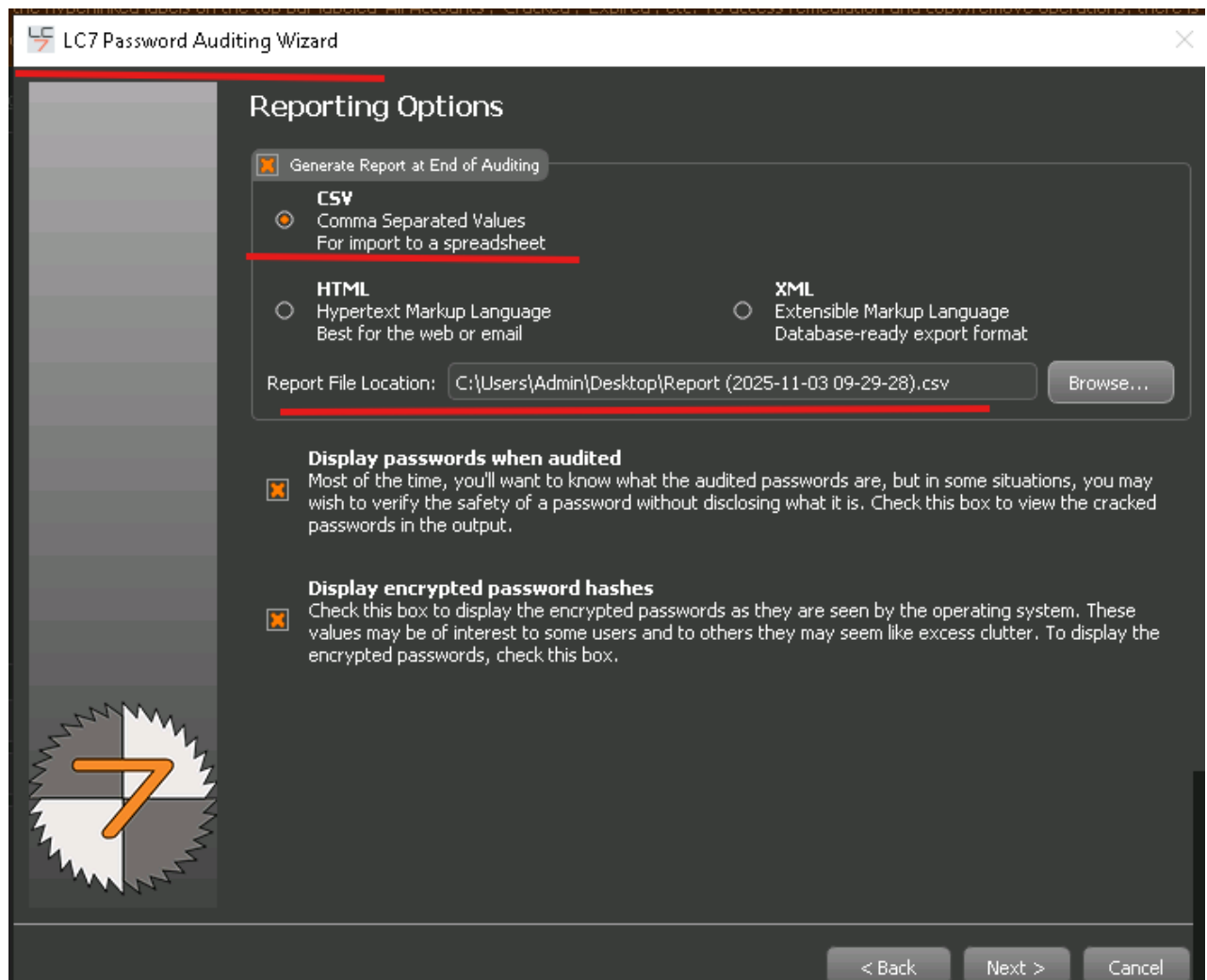
3. Une fois l'installation terminée, la fenêtre contextuelle **L0phyCrack 7 - Trial** apparaît ; cliquez sur le bouton **Procéder à l'essai** (Proceed with trial).

Remarque : Si une fenêtre contextuelle **Mise à jour disponible** apparaît, cliquez sur **Ignorer cette mise à jour**.

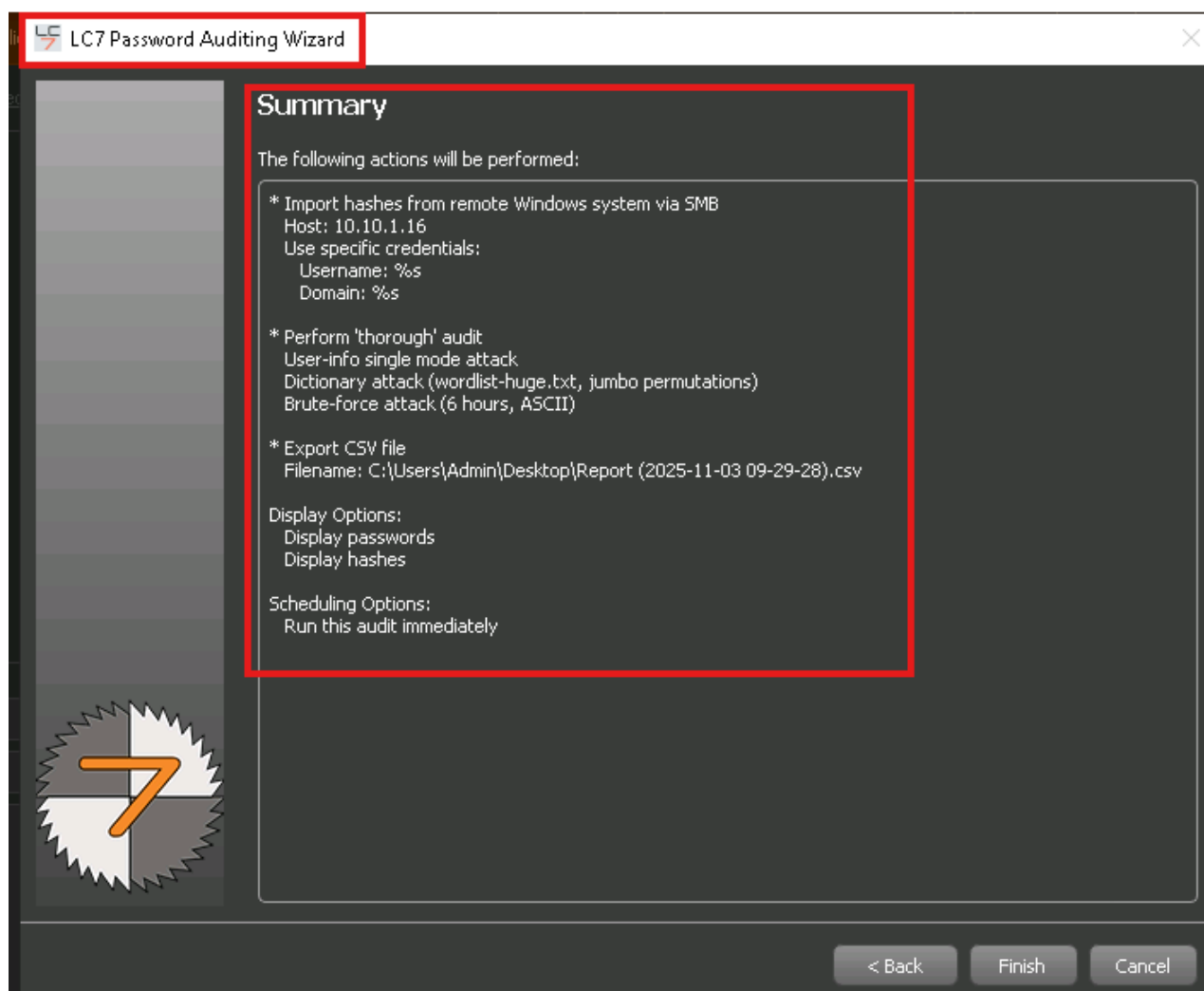
4. Dans l'assistant suivant, cliquez sur le bouton **Assistant d'audit de mot de passe** (Password Auditing Wizard).
5. La fenêtre **Assistant d'audit de mot de passe LC7** apparaît ; cliquez sur **Suivant** (Next).
6. Dans l'assistant **Choisir le type de système cible** (Choose Target System Type), assurez-vous que le bouton radio **Windows** est sélectionné et cliquez sur **Suivant**.
7. Dans l'assistant **d'importation Windows** (Windows Import), sélectionnez le bouton radio **Une machine distante** (a remote machine) et cliquez sur **Suivant**.
8. Dans l'assistant **Importation Windows depuis une machine distante (SMB)**, saisissez les détails ci-dessous :
 - a. **Hôte** : **10.10.1.16** (adresse IP de la machine distante [Windows Server 2016])
 - b. Sélectionnez le bouton radio **Utiliser les informations d'identification utilisateur spécifiques** (Use Specific User Credentials). Dans la section **Informations d'identification**, saisissez les informations de connexion de la machine **Windows Server 2016** (Nom d'utilisateur : **Administrator** ; Mot de passe : **Pa\$\$w0rd**).
 - c. Si la machine appartient à un domaine, entrez le nom de domaine dans la section **Domaine**. Ici, **Windows Server 2016** appartient au domaine **EHE.com** et cliquez sur **Suivant**



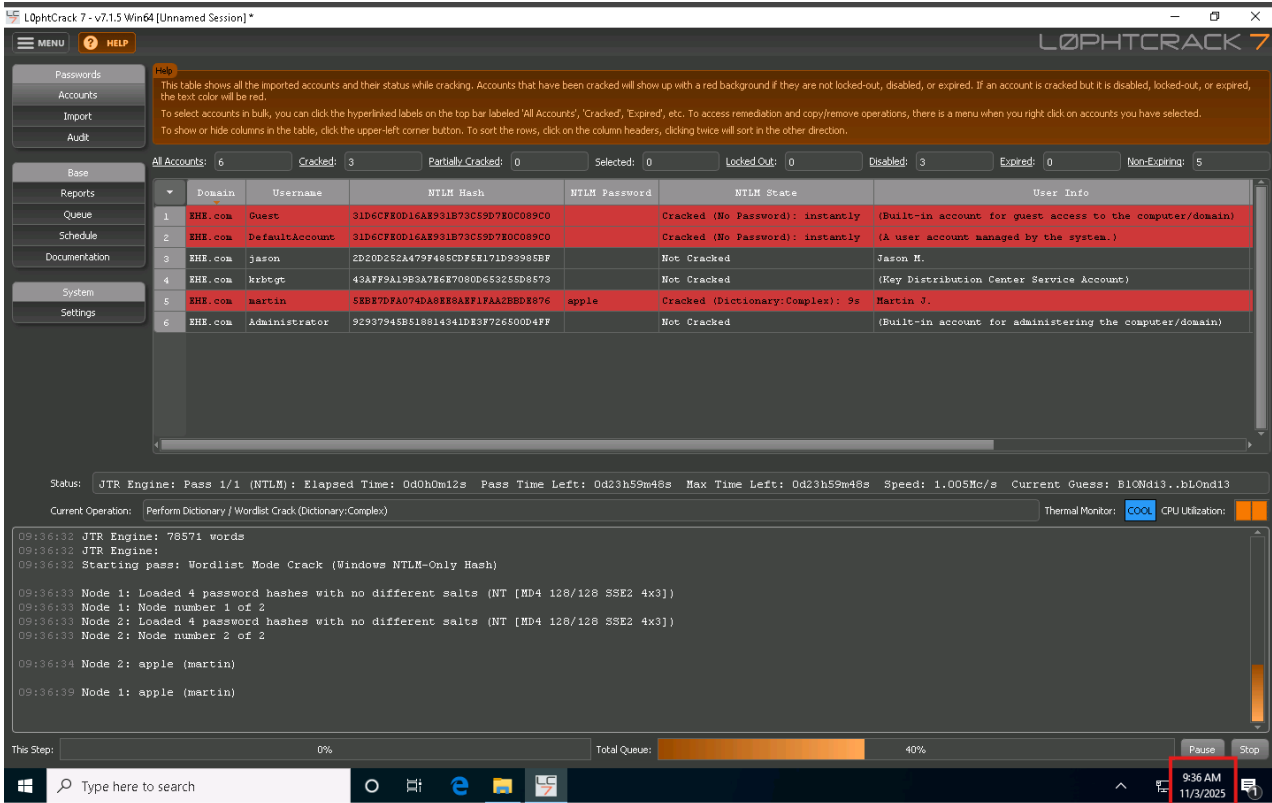
9. Dans l'assistant **Choisir un type d'audit**, sélectionnez le bouton radio **Audit approfondi des mots de passe** (Thorough Password Audit) et cliquez sur **Suivant**.
10. Dans l'assistant **Options de rapport** (Reporting options), sélectionnez l'option **Générer un rapport à la fin de l'audit** (Generate Report at end of auditing) et assurez-vous que le bouton radio **Type de rapport CSV est sélectionné**. Cliquez sur le bouton **Parcourir...** pour stocker le rapport à l'emplacement souhaité
11. La fenêtre **Choisir le nom du fichier de rapport** apparaît ; sélectionnez l'emplacement souhaité (ici, Bureau) et cliquez sur **Enregistrer**.
12. Cliquez sur **suivant** dans la fenêtre **Reporting options**.



13. L'assistant de **planification des tâches** (Job Scheduling) apparaît. Assurez-vous que le bouton radio **Exécuter ce travail immédiatement** (run this job immediately) est sélectionné et cliquez sur **Suivant**.
14. Vérifiez les détails fournis dans l'assistant **Résumé** (summary) et cliquez sur **Terminer** (finish).



15. **L0phtCrack** commence à déchiffrer les mots de passe de la machine distante.
16. **L0phtCrack** affiche les mots de passe craqués des utilisateurs disponibles sur la machine distante. Laissez tourner **L0phtCrack** pendant 30 min (ou plus si vous le voulez)et après **prenez une capture d'écran des mots de passe cassés.**



17. Pour chaque mot de passe cassé et selon les critères de complexité vus dans le cours, **évaluez si le mot utilisé est faible ou complexe? Dites pourquoi?**

Mots de passe cassé	Faible ou complexe?	Pourquoi?
Guest – Aucun mot de passe	Faible	Aucun mot de passe, accès direct
DefaultAccount – Aucun mot de passe	Faible	Aucun mot de passe, accès direct
apple (martin)	Faible	Suite de clavier connue, seulement des lettres, très prévisible.
quercy (jason)	Faible	Mot commun du dictionnaire Seulement 5 caractères Que des lettres minuscules Aucune complexité
Pa\$w0rd (Administrator)	Complexe	Contient des majuscules, des minuscules des symboles et pas dans le dictionnaire

L0phtCrack 7 - v7.1.5 Win64 [Unnamed Session] *

MENU ? HELP

Help

This table shows all the imported accounts and their status while cracking. Accounts that have been cracked will show up with a red background if they are not locked-out, disabled, or expired. If an account is cracked but it is disabled, locked-out, or expired, the text color will be red.

To select accounts in bulk, you can click the hyperlinked labels on the top bar labeled 'All Accounts', 'Cracked', 'Expired', etc. To access remediation and copy/remove operations, there is a menu when you right click on accounts you have selected.

To show or hide columns in the table, click the upper-left corner button. To sort the rows, click on the column headers, clicking twice will sort in the other direction.

All Accounts: 6 Cracked: 5 Partially Cracked: 0 Selected: 0 Locked Out: 0 Disabled: 3 Expired: 0 Non-Expiring: 5

	Domain	Username	NTLM Hash	NTLM Password	NTLM State	User Info
1	EHE.com	Guest	31D6CFE0D16AE931B73C59D7E0C089C0		Cracked (No Password): instantly	(Built-in account for guest access to the computer/domain)
2	EHE.com	DefaultAccount	31D6CFE0D16AE931B73C59D7E0C089C0		Cracked (No Password): instantly	(A user account managed by the system.)
3	EHE.com	jason	2D20D252A479F485CDF5E171D93985BF	qwerty	Cracked (Dictionary:Complex): 41s	Jason M.
4	EHE.com	krbtgt	43AFF9A19B3A7E6E7080D65325D8573		Not Cracked	(Key Distribution Center Service Account)
5	EHE.com	martin	5EBE7DFA074DA8EE8AEF1FAA2BED8976	apple	Cracked (Dictionary:Complex): 9s	Martin J.
6	EHE.com	Administrator	92937945B518814341DE3F726500D4FF	Pa\$\$w0rd	Cracked (Dictionary:Complex): 41s	(Built-in account for administering the computer/domain)

Status: Paused

Current Operation: Paused

Thermal Monitor: COOL CPU Utilization: 0%

09:36:34 Node 2: apple (martin)

09:36:39 Node 1: apple (martin)

09:37:11 Node 2: Pa\$\$w0rd (Administrator)

09:37:13 Node 2: qwerty (jason)

09:37:15 Node 1: Pa\$\$w0rd (Administrator)

10:07:53 Paused

This Step: 2% Total Queue: 40%

Resume Stop

Type here to search

10:08 AM

	Domain	Username	NTLM Hash	NTLM Password	NTLM State	User Info
1	EHE.com	Guest	31D6CFE0D16AE931B73C59D7E0C089C0		Cracked (No Password): instantly	(Built-in account for guest access to the computer/domain)
2	EHE.com	DefaultAccount	31D6CFE0D16AE931B73C59D7E0C089C0		Cracked (No Password): instantly	(A user account managed by the system.)
3	EHE.com	jason	2D20D252A479F485CDF5E171D93985BF	qwerty	Cracked (Dictionary:Complex): 41s	Jason M.
4	EHE.com	krbtgt	43AFF9A19B3A7E6E7080D65325D8573		Not Cracked	(Key Distribution Center Service Account)
5	EHE.com	martin	5EBE7DFA074DA8EE8AEF1FAA2BED8976	apple	Cracked (Dictionary:Complex): 9s	Martin J.
6	EHE.com	Administrator	92937945B518814341DE3F726500D4FF	Pa\$\$w0rd	Cracked (Dictionary:Complex): 41s	(Built-in account for administering the computer/domain)